SEGURANÇA DE APLICAÇÕES • AUDITORIA DE CÓDIGO

Relatório de Auditoria de Segurança — LevelUp User

21 de setembro de 2026 • pt-BR

Resultado: 0 vulnerabilidades confirmadas nas cinco categorias solicitadas.

Escopo: checkout local, código da aplicação e servidor estático, configuração, documentação, CI/deploy, histórico Git alcançável pelas referências locais e bundle de produção reconstruído.

```
Revisão-base: 5bae431deae12e590f22cc74b2f90c271650d1d5
```

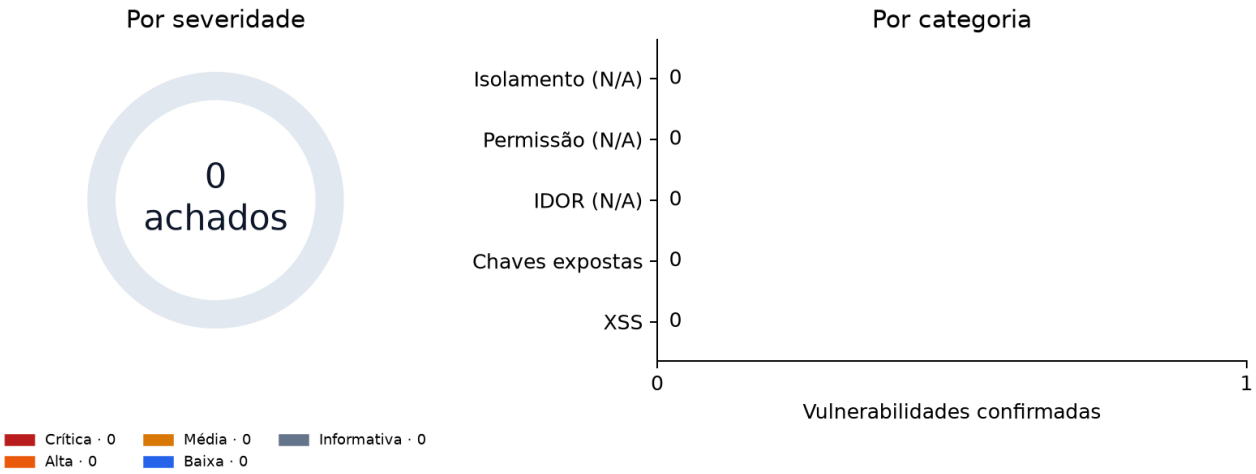
Nota metodológica

A stack foi identificada pelos arquivos reais, não pelo PRD de Brev.ly. Isolamento foi mapeado para persistência/tenant; autorização para gates de papel e ações HTTP; IDOR para todos os handlers; segredos para fonte, histórico e bundle; XSS para origem dos dados e destinos DOM/HTML/URL. A severidade exige um caminho de exploração comprovado.

O repositório é um portfólio público. O encurtador aparece apenas como serviço “Coming soon”. Não foi inferida uma API que não existe.

Ausência de achados não equivale a garantia de segurança. Configuração de produção, serviços externos e segredos do provedor não foram inspecionados.

Resumo executivo



Crítica 0 • Alta 0 • Média 0 • Baixa 0 • Informativa 0. A rosca cinza representa ausência de achados; não atribui proporções a uma soma zero. N/A não significa controle de autorização testado: significa ausência dessa funcionalidade.

Categoria	Resultado e mapeamento
1. Banco sem tranca	Não aplicável. Sem banco, ORM, queries, usuários ou tenants. Nenhum mecanismo de isolamento é necessário à entrega de conteúdo público atual.
2. Permissão no navegador	Não aplicável. Sem papéis, login, administração ou endpoints privilegiados. Consentimento de telemetria não é autorização de servidor.
3. IDOR	Não aplicável a objetos privados. 1/1 handler HTTP auditado integralmente; não consulta nem altera objetos de negócio por ID.
4. Chaves expostas	Aplicável; nenhuma credencial confirmada em fonte, histórico local ou bundle reconstruído.
5. XSS	Aplicável no frontend; nenhum fluxo explorável confirmado. Backend não produz templates ou e-mails com input.

Stack detectada e cobertura HTTP

Camada	Evidência
Linguagem e frontend	TypeScript strict (tsconfig.app.json:16), React 18.3, React Router 7.18, Vite 5.4, Tailwind 3.4; package.json e lockfile.
Servidor	Node.js 20 declarado; node:http em scripts/serve.mjs:1–3,135. Não há Fastify/Express nem API de negócio.
Persistência e auth	Nenhum banco, ORM/query builder, RLS, middleware de tenant, sessão autenticada ou JWT. localStorage guarda preferências; sessionStorage guarda marcadores locais.
Deploy	Procfile:1; GitHub Actions ci.yml e deploy.yml; buildpacks/Easypanel e alternativa Cloudflare Pages documentados. Sem Dockerfile, compose, Helm ou Terraform no checkout.

Handler único: scripts/serve.mjs:74–129, registrado em :135. Cobertura integral dos ramos abaixo; rotas React não foram contadas como APIs.

Ramo / linhas	Verificação
75–79	Métodos diferentes de GET/HEAD recebem 405; nenhuma escrita é executada.
49–71; 83–101	URL decodificada, caminho resolvido dentro de dist; escape lexical recebe 400; URL inválida e recurso ausente recebem 404.
103–119	MIME por extensão, nosniff e ETag; correspondência de ETag gera 304 sem corpo.
121–128	GET transmite arquivo; HEAD encerra sem corpo. Conteúdo da query não é interpolado em HTML.
src/app/App.tsx:56–63	Rotas /, /privacy, /terms, /projects, /services e * são públicas; sem gate de papel a cruzar com endpoint.

Nove testes HTTP locais passaram: GET/HEAD /; POST /links, PATCH e DELETE; asset ausente; travessia codificada; percent-encoding inválido; payload HTML em query sem reflexão. Os detalhes estão em http-checks.json. Não houve tráfego de teste à produção.

Pontos fortes — evidências verificadas

scripts/serve.mjs:51–56

```
const isInsideDist = requestedFile === distDirectory || requestedFile.startsWith(`${distDirectory}${sep}`);
```

Bloqueia o escape lexical do diretório publicado; teste codificado retornou 400. Não é uma garantia contra symlinks criados por um operador no dist.

scripts/serve.mjs:75–78

```
if (request.method !== "GET" && request.method !== "HEAD") { response.writeHead(405, { Allow: "GET, HEAD"
});
```

A superfície atual não oferece escrita HTTP.

src/pages/ProjectsPage.tsx:116–126

```
<h2 ...>{project.title}</h2>
<p ...>{project.description}</p>
```

Texto via JSX; não há injeção de HTML bruto neste fluxo.

src/lib/tracking.ts:48–50,70

```
`https://www.googletagmanager.com/gtag/js?id=${encodeURIComponent(measurementId)}`
```

Script com origem fixa e ID codificado. Meta usa URL fixa. O visitante não controla a URL do script.

.github/workflows/deploy.yml:22–23; ci.yml:67

```
EASYPANEL_DEPLOY_WEBHOOK_URL: ${{ secrets.EASYPANEL_DEPLOY_WEBHOOK_URL }}
token: ${{ secrets.CODECOV_TOKEN }}
```

Credenciais referenciadas pelo cofre de Actions; nenhum valor real encontrado nessas linhas.

src/lib/pageMetadata.ts:13,19,25

```
existingTag.content = content;
metaTag.content = content;
document.title = title;
```

Metadados atribuídos como propriedades, sem parsing de HTML.

Outros controles observados: consentimento de monitoring antes da inicialização (monitoring.ts:24–36; telemetry.ts:48–69), PII padrão desativada (monitoring.ts:45), consentimento validado como booleanos (privacyConsent.ts:37–50). Não foi feita certificação jurídica nem auditoria completa de privacidade.

Achados detalhados por categoria

Nenhuma vulnerabilidade verificável foi identificada. Não existem linhas de achado ou chips de severidade a preencher; a tabela registra o resultado por categoria sem criar falsos positivos.

Severidade	Arquivo:linha	Descrição
— / N/A	package.json; src/data/projects.ts:15–71	Isolamento: dados estáticos públicos, sem dono/tenant ou consultas.
— / N/A	src/app/App.tsx:56–63; scripts/serve.mjs:75–79	Permissões: sem papel de usuário e sem ação privilegiada.
— / N/A	scripts/serve.mjs:49–71,74–129	IDOR: todos os handlers (1/1) lidos; nenhum objeto privado endereçado por ID.
— / sem achado	.env.example:1–8; .github/workflows/deploy.yml:22–23	Segredos: configurações públicas/vazias e referências ao cofre. Não há default de senha ou segredo a rejeitar no startup.
— / sem achado	src/pages/ProjectsPage.tsx:73,134,239; src/data/projects.ts:20,33,39,43,65,69	URLs são constantes HTTPS ou caminhos locais; sem origem em input do visitante.
— / sem achado	src/pages/PrivacyPage.tsx:58,83–84	Contato vem da configuração de build, prefixado por mailto: e renderizado como texto JSX.
— / sem achado	src/lib/liquidGlass.ts:31–49,74–80; components/effects/LiquidGlassNavigation.tsx:7,39–42	Seletor de efeito é constante; outerHTML em liquid-gl é leitura para assinatura, não escrita de HTML.

XSS: não há dangerouslySetInnerHTML, innerHTML de escrita, document.write, eval ou new Function no código próprio, nem renderizador Markdown/HTML. Nenhuma biblioteca de sanitização foi encontrada no manifesto/lockfile. Sem um sink de HTML não confiável, essa ausência não constitui falha. O backend entrega arquivos e não renderiza templates de e-mail.

Pontos fracos / riscos centrais: nenhum risco explorável confirmado dentro do escopo. A visibilidade é limitada ao repositório e ao build local; coletor OTLP, conta Sentry, hospedagem, configurações privadas e sites externos não foram auditados. Não foram promovidas lacunas de observabilidade a vulnerabilidades.

Histórico, bundle e validação

Histórico: 31 commits alcançáveis por refs locais; clone não shallow; 193 blobs textuais únicos. Busca por chaves privadas, tokens de provedores, JWT, URLs com credenciais, atribuições de segredo e defaults de shell, complementada por revisão de linhas com palavras-chave. Sem validação de credenciais contra terceiros.

Seis candidatos de defaults foram descartados: ${VPS_PORT:-22} em uma versão de deploy.yml e ${PORT:-3000} em cinco versões de package.json. São portas públicas, não segredos. Exemplos BOT_TOKEN, YOUR_PUBLIC_KEY e YOUR_GLITCHTIP_DSN são placeholders, sem credencial operacional embutida.

Limite do histórico: não houve fetch adicional; referências remotas não presentes, commits inalcançáveis, objetos removidos, logs de CI e conteúdo de cofres não entram nessa conclusão. Uma busca por padrões não prova ausência absoluta de todo segredo possível.

Bundle: 14 arquivos textuais em dist reconstruídos por npm run validate; nomes e SHA-256 em scan-results.json. Nenhum candidato a segredo nessas saídas. O build local não continha a configuração opcional de telemetria; o código-fonte condicionado foi lido separadamente. O bundle publicado não foi coletado.

Verificação	Resultado
npm run validate	Passou: ESLint/Biome, arquitetura, dead code, npm audit de dependências de produção, Vitest e build.
Testes existentes	7 arquivos / 15 testes aprovados. Cobertura publicada de linhas: 95,08% no subconjunto configurado, não em toda a aplicação.
npm audit --omit=dev	0 vulnerabilidades reportadas nessa execução. Esse número não substitui análise de autorização ou XSS.
HTTP local	9/9 verificações passaram; resultados em http-checks.json.
Mutação e E2E	Não executados nesta auditoria. Não houve alteração de lógica de negócio; validate não inclui Playwright.
PDF	A4, margens de 20 mm, cabeçalho/rodapé, gráficos e rasterização por página; ver pdf-verification.json e previews/.

Recomendações priorizadas

P1 — Antes de introduzir dados privados: definir identidade, dono/tenant e autorização no servidor; testar acesso cruzado em cada operação. Recomendação futura, não correção de falha atual.

P2 — Antes de publicar nova configuração: examinar os VITE_* e o bundle exato destinado à produção; manter tokens privados no servidor/cofre. Não há vazamento confirmado a rotacionar.

P3 — Repetir esta revisão quando houver API, CMS, URLs editáveis ou renderização de HTML/Markdown. Acrescentar testes de fonte→sink e de posse às novas funcionalidades.

Cobertura arquivo por arquivo

Inventário completo com linhas e hashes: inventory.json. Todos os arquivos textuais rastreados foram incluídos na busca de segredos; a revisão manual de fluxos cobriu os grupos abaixo. Não se afirma revisão linha a linha de bibliotecas de terceiros inteiras.

Arquivos / linhas	Cobertura e conclusão
scripts/serve.mjs:1–137	Único handler e todas as funções auxiliares: sem persistência, escrita ou HTML interpolado.
src/app/App.tsx:1–79; routes/routes.ts:1–13; main.tsx:1–30	Inventário completo de rotas, inicialização e ausência de auth/gates de papel.
src/pages/HomePage.tsx; NotFoundPage.tsx; TermsPage.tsx; ServicesPage.tsx (integrais)	Páginas públicas com JSX e rotas constantes; serviços são apenas anúncios.
src/pages/ProjectsPage.tsx:1–317; data/projects.ts:1–71	Origem de texto/URLs, imagens, href e callbacks rastreados.
src/pages/PrivacyPage.tsx:1–110	Contato de build e conteúdo estático; não é uma interface administrativa.
src/components/ (todos os arquivos TSX)	Button, ProfilePhoto, PageContainer, feedback, consentimento e navegação: sem sink próprio de HTML bruto.
src/lib/ (todos os arquivos TS)	Monitoring, tracking, telemetry, privacyConsent, metadata, release, chunkRecovery e liquidGlass: fontes, scripts e uso de storage revisados.
build/; scripts/check-bundle.mjs; vite.config.ts	Release serializado com JSON.stringify; orçamento de bundle e testes de hospedagem; sem segredo hardcoded.
.github/; Procfile; public/_headers; .env.example; .gitignore	CI, deploy e configuração atual; ausência de arquivos Docker/Helm/Terraform inventariada.
README.md; docs/monitoring.md; docs/superpowers/plans/2026-05-03-sentry-monitoring.md	Documentação e exemplos de credenciais revisados; placeholders não tratados como vazamento.
package*.json; configs; e2e/; testes; public/; index.html	Manifestos, lock, arquivos de build, testes e ativos textuais incluídos nas buscas; inventário fornece extensão exata.

ISSUES PARA O GITHUB

Não há achados acionáveis confirmados nas cinco categorias. Portanto, não foram geradas issues de vulnerabilidade nem blocos fictícios de falha. As recomendações preventivas da página anterior não são achados e não foram convertidas em tickets de segurança.

A issue operacional #22 registra a produção deste relatório; ela não representa vulnerabilidade. Nenhuma correção de aplicação foi feita nesta auditoria.

Quando uma nova auditoria confirmar uma falha, o bloco de issue deverá conter título [Segurança], labels, descrição e explorabilidade, arquivo:linha e trecho, impacto, correção e checklist verificável. Esta edição mantém a seção final vazia de tickets para evitar spam e acusações sem evidência.

Referência operacional: https://github.com/danilomoreiraai/levelUpUser/issues/22